TECHNOVA SOLUTIONS PVT. LTD.
INFORMATION SECURITY POLICY

Document ID	TN-ADM-POL-001
Document Type	Administration / Information Security Policy
Document Owner	Administration Department / Information Security
Approving Authority	Managing Director
Classification	Internal — Confidential
Version	1.0
Effective Date	01 April 2026
Review Cycle	Annual
Status	Active
Supersedes	New Policy

1. Purpose

This Information Security Policy establishes the principles, responsibilities, and minimum requirements used by TechNova Solutions Pvt. Ltd. (“TechNova” or “the Company”) to protect Company information and technology resources.

The policy is intended to preserve confidentiality, integrity, and availability while enabling employees and authorized third parties to perform legitimate business activities.

2. Scope

This policy applies to employees, contractors, consultants, temporary personnel, suppliers, and other authorized users who access Company information, systems, devices, applications, networks, facilities, or services.

It applies to information in electronic, physical, verbal, printed, and other forms, regardless of where it is processed or stored.

3. Information Security Objectives

- Protect confidential and sensitive Company information from unauthorized access or disclosure.
- Maintain integrity and accuracy of business information.
- Maintain availability of critical systems and information.
- Reduce information-security risks through appropriate preventive and detective controls.
- Support legal, regulatory, contractual, and customer obligations.
- Ensure security responsibilities are understood and consistently applied.

4. Security Principles

- Need-to-know and least privilege.
- Defense in depth.
- Secure-by-design and secure-by-default practices.
- Risk-based controls.
- Accountability and traceability.
- Timely identification and response to security events.

- Continuous improvement.

5. Information Security Governance

Administration and designated Information Security personnel coordinate the Company's information-security framework. Business, technology, and system owners remain accountable for security within their areas of responsibility.

Security requirements may be supported by more detailed Company policies, standards, procedures, and technical controls.

6. Roles and Responsibilities

Role	Responsibility
Management	Provide direction, resources, risk decisions, and oversight for information security.
Information Security	Define security requirements, advise on risk, coordinate security incidents, and monitor the security program.
System / Data Owners	Classify information, approve access, define appropriate controls, and review risk.
Engineering / IT	Implement and maintain technical security controls and secure operational practices.
Managers	Ensure personnel follow security requirements and report material risks.
Employees / Users	Protect credentials, information, devices, and systems and promptly report suspected incidents.

7. Information Classification

Information should be classified according to sensitivity, business impact, confidentiality requirements, and applicable obligations.

Classification	Typical Handling
Public	Information approved for unrestricted external distribution.
Internal	Routine Company information intended primarily for authorized personnel.
Confidential	Information that could cause material business, customer, employee, contractual, or operational impact if improperly disclos
Restricted	Highly sensitive information requiring strict access, handling, and disclosure controls.

8. Information Handling

- Use information only for legitimate business purposes.
- Share information only with authorized recipients.
- Apply appropriate protection based on classification.
- Do not leave sensitive information unattended.
- Use approved storage and communication services.
- Dispose of information securely when no longer required.

9. Access Control

Access to systems and information must be authorized, appropriate to job responsibilities, and periodically reviewed.

- Unique user accounts where practical
- Least-privilege access
- Role-based access
- Timely removal of unnecessary access
- Periodic access review

- Logging of security-relevant access

10. Authentication

Users must authenticate using approved mechanisms. Strong authentication controls should be used for systems and information requiring elevated protection.

Credentials must never be intentionally shared between users.

11. Password and Credential Protection

- Use passwords or authentication secrets that meet Company technical requirements.
- Do not disclose passwords to other people.
- Do not store credentials in unapproved locations.
- Report suspected credential compromise immediately.
- Use approved password-management mechanisms where provided.

12. Multi-Factor Authentication

Multi-factor authentication should be enabled for systems designated by Information Security or system owners, particularly for privileged, remote, administrative, and sensitive access.

13. Privileged Access

Administrative access must be limited to authorized personnel and used only when required.

- Use separate privileged identities where required.
- Avoid using administrative access for routine activities.
- Log and review privileged activity where appropriate.
- Remove privileged access when no longer required.

14. User Lifecycle

Access must be aligned with the employee or contractor lifecycle.

- Provision access after authorization.
- Modify access when roles change.
- Suspend or revoke access promptly at separation.
- Review exceptional or temporary access.

15. Remote Access

Remote access to Company systems must use approved secure mechanisms and comply with access-control, endpoint-security, and remote-work requirements.

Users must not bypass security controls to obtain remote connectivity.

16. Device Security

- Use approved Company-managed devices where required.
- Keep operating systems and security software current.
- Use screen locking and authentication.
- Protect devices against theft and unauthorized use.
- Report lost or stolen devices promptly.

17. Endpoint Protection

Company-managed endpoints should use appropriate security controls such as malware protection, security configuration, patching, logging, and device-management capabilities based on risk.

18. Mobile Devices

Mobile devices accessing Company information must use appropriate authentication and security controls. Sensitive information should not be stored locally unless authorized and protected.

19. Network Security

Company networks and connectivity must be designed and operated to reduce unauthorized access and protect information in transit.

- Network segmentation where appropriate
- Secure remote connectivity
- Controlled administrative access
- Monitoring of relevant security events
- Protection of network infrastructure

20. Wireless Security

Users must connect Company devices using approved wireless networks or secure mechanisms. Untrusted public networks should be treated as higher-risk environments.

21. Encryption

Encryption should be used where required by information sensitivity, technical risk, contractual requirements, or Information Security standards.

Encryption keys and secrets must be protected separately from the information they protect where technically appropriate.

22. Data in Transit

Sensitive information transmitted across untrusted or public networks must use approved secure protocols and mechanisms.

23. Data at Rest

Sensitive information stored on endpoints, servers, databases, backups, or removable media should receive appropriate protection based on classification and risk.

24. Removable Media

Use of removable storage for Company information should be minimized and controlled according to security requirements.

- Use approved media where required.
- Encrypt sensitive information where appropriate.
- Do not use unknown or untrusted storage devices.
- Securely erase media before disposal or reuse.

25. Email and Messaging

Company communication systems must be used responsibly. Sensitive information should be shared only with authorized recipients and through approved mechanisms.

- Verify recipients.
- Treat unexpected attachments and links cautiously.
- Do not forward confidential information to personal accounts.
- Report suspected phishing or malicious messages.

26. Phishing and Social Engineering

Users must remain alert to attempts to obtain credentials, confidential information, payments, or unauthorized access through deception.

Suspicious requests should be verified through an independent trusted channel before action.

27. Internet and Web Use

Internet access is provided for legitimate business use and must not be used in ways that introduce unacceptable security, legal, or operational risk.

28. Acceptable Use

- Do not intentionally disable security controls.
- Do not access information without authorization.
- Do not introduce malicious software.
- Do not use Company systems for unlawful activity.
- Do not attempt unauthorized security testing.
- Do not circumvent access restrictions.

29. Software and Applications

Software installed or used for Company business must be authorized and managed appropriately.

Unapproved applications, browser extensions, scripts, or services may introduce security or data-protection risks and should not be used for sensitive Company activities without authorization.

30. Vulnerability Management

Security vulnerabilities should be identified, assessed, prioritized, and remediated according to risk.

- Critical vulnerabilities receive urgent attention.
- Affected systems should be tracked to remediation.
- Temporary mitigations may be applied when full remediation is not immediately possible.
- Exceptions should be documented and risk-accepted by authorized personnel.

31. Patch Management

Operating systems, applications, infrastructure, and security tools should receive security updates according to risk and operational requirements.

32. Secure Configuration

Systems should use approved secure configurations. Unnecessary services, ports, accounts, software, and privileges should be disabled or removed where practical.

33. Logging and Monitoring

Security-relevant events should be logged and monitored where appropriate to support detection, investigation, troubleshooting, and accountability.

- Authentication events
- Privileged actions
- Security alerts
- Material configuration changes
- Relevant application and infrastructure events

34. Log Protection

Security logs must be protected against unauthorized alteration and access. Retention should follow applicable operational, security, and data-retention requirements.

35. Security Incident Reporting

Suspected security incidents must be reported promptly. Examples include unauthorized access, credential compromise, malware, data exposure, phishing, lost devices, suspicious system activity, and security-control failures.

Users should preserve relevant information and avoid actions that could destroy evidence unless immediate containment is necessary and authorized.

36. Security Incident Response

Information Security coordinates or supports security incident response according to the Company's Incident Response framework.

- Identification
- Triage and severity assessment
- Containment
- Investigation and evidence preservation
- Eradication or remediation
- Recovery
- Validation
- Post-incident review

37. Data Breach and Exposure

Suspected unauthorized disclosure, loss, or exposure of sensitive information must be escalated immediately for assessment.

Potential notification, contractual, legal, regulatory, customer, or employee implications must be evaluated by the appropriate functions.

38. Malware and Ransomware

Suspected malware or ransomware must be reported immediately. Users should not attempt unauthorized removal, negotiation, evidence destruction, or recovery actions that could increase impact.

39. Third-Party Security

Third parties that access Company information or systems must meet applicable security requirements proportionate to risk.

- Security requirements in agreements where appropriate
- Access limitation
- Confidentiality obligations

- Security review or due diligence for higher-risk services
- Incident notification expectations

40. Cloud Security

Cloud services must have accountable owners and appropriate identity, access, configuration, logging, data-protection, and lifecycle controls.

41. Application Security

Applications developed or maintained by TechNova must incorporate security throughout the development lifecycle.

- Input validation
- Authentication and authorization
- Secure error handling
- Dependency management
- Security testing
- Protection of secrets
- Logging of relevant events

42. Secure Development

Engineering teams must follow applicable coding, code-review, testing, deployment, and access-control requirements. Security issues identified during development must be addressed according to risk.

43. Database Security

Databases containing Company or customer information must use appropriate access controls, authentication, encryption, logging, backup, and maintenance controls.

44. API Security

APIs must enforce appropriate authentication, authorization, input validation, rate controls where needed, secure transport, and logging.

45. Secrets Management

Passwords, API keys, tokens, private keys, certificates, and other secrets must not be embedded in source code, public repositories, documentation, or unauthorized storage.

46. Backup Security

Backups containing sensitive information must be protected against unauthorized access, alteration, and destruction. Backup access must be restricted and recovery capability tested according to criticality.

47. Business Continuity

Information-security requirements must be maintained during business continuity and alternate operating arrangements. Emergency conditions do not automatically justify uncontrolled access or insecure handling.

48. Physical Security

Physical access to offices, server areas, storage areas, and other sensitive locations must be controlled according to risk.

- Use authorized access mechanisms.
- Do not allow unauthorized persons to follow through controlled entrances.

- Protect sensitive equipment.
- Report suspicious physical activity.

49. Clear Desk and Clear Screen

Sensitive documents and information should not be left exposed when unattended. Users should lock screens and secure physical records appropriately.

50. Visitor Management

Visitors to controlled areas must follow applicable visitor and escort requirements. Access to sensitive systems or information must not be provided merely because a person is physically present.

51. Information Disposal

Information and information-bearing media must be disposed of according to applicable retention and secure-disposal requirements.

52. Data Retention

Information must not be retained indefinitely without a legitimate business, legal, contractual, or operational reason. Applicable retention requirements should be followed.

53. Privacy and Personal Information

Personal information must be processed only for legitimate purposes and protected against unauthorized access, use, disclosure, alteration, or loss.

54. Security Awareness

Employees and contractors should receive security awareness guidance appropriate to their roles.

- Phishing awareness
- Credential protection
- Information handling
- Incident reporting
- Remote-work security
- Secure use of Company devices

55. Security Training for Sensitive Roles

Personnel with privileged access, security responsibilities, development responsibilities, or access to highly sensitive information may require additional role-specific training.

56. Security Assessments

Information Security may perform or coordinate assessments, reviews, vulnerability evaluations, configuration checks, or other activities to identify security weaknesses.

57. Security Testing

Security testing must be authorized, scoped, and conducted in a manner that minimizes disruption and protects Company information.

58. Risk Acceptance

Security risks that cannot be immediately remediated must be documented and accepted by an appropriately authorized owner based on the Company's risk-management process.

59. Exceptions

Exceptions to this policy require documented justification, defined scope and duration, compensating controls where appropriate, and approval by the designated authority.

60. Compliance and Violations

Violations may result in corrective action, access restriction, disciplinary action, contractual action, or other measures appropriate to the circumstances.

Suspected deliberate misuse, concealment, unauthorized access, or intentional circumvention of security controls may be investigated.

61. Frequently Asked Questions

What should I do if I suspect a security incident?

Report it immediately through the approved security or incident-reporting channel. Do not wait for complete evidence.

Can I share my password with IT support?

No. Credentials must not be intentionally shared. Use approved support and account-recovery mechanisms.

Can I store Company files in my personal cloud account?

No, unless specifically authorized under an approved Company process.

What if I click a suspicious link?

Report the event promptly and follow security instructions. Do not conceal the event because you are uncertain about its impact.

Why is least privilege important?

It limits the amount of information and systems a compromised or misused account can access.

Are remote workers covered by this policy?

Yes. Security requirements apply regardless of where Company work is performed.

Who can approve a security exception?

The designated authority based on the risk, system, and applicable Company governance.

What happens to access when an employee leaves?

Access should be revoked promptly according to the user lifecycle and exit processes.

Should security incidents be investigated by employees themselves?

Only within their authorized responsibilities. Material security investigations should be coordinated with Information Security.

Does this policy replace detailed security procedures?

No. It establishes baseline requirements; supporting policies, standards, and procedures may provide additional controls.

62. Revision History

Version	Effective Date	Description	Owner	Approval
1.0	01 April 2026	Initial release of Information Security Policy	Administration / Information Security Director	Managing Director

63. Related Documents

- Access Control Policy
- Data Retention Policy
- Disaster Recovery Policy
- Business Continuity
- Incident Response
- Asset Management
- Employee Handbook
- Engineering Handbook
- Coding Standards
- Testing Standards

END OF DOCUMENT

TN-ADM-POL-001 | Version 1.0 | Internal — Confidential | Administration / Information Security